Vulnerability Assessment Report

Proton IP Scanner 1.6.0 | 2026-11-06 15:57 UTC

Targets	192.168.1.1-254 (DEMO DATA)
Hosts assessed	3
Open services	6
Scan speed	Normal (fast) · Nmap 7.94SVN
Duration	41 seconds
Vulnerability data	NVD (CVSS, CISA KEV) and FIRST EPSS, looked up online during the scan
Reviewed	1 of 13 findings marked as reviewed

Summary

3	2	4	1	1	2
Critical	High	Medium	Low	Review	Info

Counts are findings per host. 10 distinct vulnerabilities (excluding informational), 2 of them known to be exploited (CISA KEV).

Note: Demo note: NVD could not be reached (example).

Top 10 vulnerabilities by priority

#	Severity	ID	Vulnerability	Hosts	CVSS	EPSS	PPR	KEV	Review
1	CRITICAL	CVE-2021-42013	Apache httpd 2.4.49: Path traversal and re…	1	9.8	94.0%	9.9	Yes	
2	CRITICAL	PIS-0003	Redis database accessible without authen…	1	9.3	-	9.2		
3	HIGH	CVE-2021-41773	Apache httpd 2.4.49: Path traversal and fil…	1	7.5	94.0%	8.5	Yes	
4	HIGH	CVE-2024-6387	OpenSSH 8.9p1: Signal handler race cond…	1	8.1	40.0%	7.4		
5	CRITICAL	CVE-2023-38408	OpenSSH 8.9p1: Remote code execution t…	1	9.8	6.0%	6.9		
6	MEDIUM	PIS-0002	Anonymous FTP login allowed	1	6.9	-	6.5		
7	MEDIUM	CVE-2023-48795	OpenSSH 8.9p1: Terrapin attack: prefix tr…	1	5.9	55.0%	6.5		
8	MEDIUM	PIS-0001	Telnet service enabled (cleartext remote lo…	1	6.0	-	5.6		
9	MEDIUM	PIS-0009	Login page served over unencrypted HTTP	1	5.9	-	5.1		
10	LOW	PIS-0013	Unencrypted FTP service	1	2.1	-	2.1		

Findings

CRITICAL **CVE-2021-42013 | KNOWN EXPLOITED (CISA KEV)**

Apache httpd 2.4.49: Path traversal and remote code execution in Apache HTTP Server 2.4.49 and 2.4.50

CVSS 3.1: 9.8 | EPSS: 94.00% (percentile 97) | PPR: 9.9 | Published: 2024-01-01 | Confidence: Version match

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

Affected (1): 192.168.1.10:80 - Apache httpd 2.4.49

Path traversal and remote code execution in Apache HTTP Server 2.4.49 and 2.4.50. (Demo data for screenshots.)

Solution: Update Apache httpd 2.4.49 to the latest version.

Evidence: Version-based match: Apache httpd 2.4.49 announced on port 80.

https://nvd.nist.gov/vuln/detail/CVE-2021-42013

CRITICAL **PIS-0003**

Redis database accessible without authentication

CVSS 4.0: 9.3 | EPSS: - | PPR: 9.2 | Confidence: Confirmed

`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N`

Affected (1): 192.168.1.10:6379

The Redis server answers commands without a password. Anyone who can reach it can read and delete all data, and attackers commonly use open Redis servers to write SSH keys or cron jobs and take over the machine.

Solution: Set a password (requirepass / ACL users), bind Redis to 127.0.0.1 unless remote access is needed, and enable protected-mode.

Evidence: INFO command answered without a password.

HIGH **CVE-2021-41773 | KNOWN EXPLOITED (CISA KEV)**

Apache httpd 2.4.49: Path traversal and file disclosure in Apache HTTP Server 2.4.49

CVSS 3.1: 7.5 | EPSS: 94.00% (percentile 97) | PPR: 8.5 | Published: 2024-01-01 | Confidence: Version match

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`

Affected (1): 192.168.1.10:80 - Apache httpd 2.4.49

Path traversal and file disclosure in Apache HTTP Server 2.4.49. (Demo data for screenshots.)

Solution: Update Apache httpd 2.4.49 to the latest version.

Evidence: Version-based match: Apache httpd 2.4.49 announced on port 80.

https://nvd.nist.gov/vuln/detail/CVE-2021-41773

HIGH **CVE-2024-6387**

OpenSSH 8.9p1: Signal handler race condition in sshd (regreSSHion)

CVSS 3.1: 8.1 | EPSS: 40.00% (percentile 70) | PPR: 7.4 | Published: 2024-01-01 | Confidence: May be backported

`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H`

Affected (1): 192.168.1.10:22 - OpenSSH 8.9p1

Signal handler race condition in sshd (regreSSHion). (Demo data for screenshots.)

Solution: Update OpenSSH 8.9p1 to the latest version.

Evidence: Version-based match: OpenSSH 8.9p1 announced on port 22.

https://nvd.nist.gov/vuln/detail/CVE-2024-6387

CRITICAL **CVE-2023-38408**

OpenSSH 8.9p1: Remote code execution through ssh-agent PKCS#11 provider loading

CVSS 3.1: 9.8 | EPSS: 6.00% (percentile 53) | PPR: 6.9 | Published: 2024-01-01 | Confidence: May be backported

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

Affected (1): 192.168.1.10:22 - OpenSSH 8.9p1

Remote code execution through ssh-agent PKCS#11 provider loading. (Demo data for screenshots.)

Solution: Update OpenSSH 8.9p1 to the latest version.

Evidence: Version-based match: OpenSSH 8.9p1 announced on port 22.

https://nvd.nist.gov/vuln/detail/CVE-2023-38408

MEDIUM **PIS-0002**

Anonymous FTP login allowed

CVSS 4.0: 6.9 | EPSS: - | PPR: 6.5 | Confidence: Confirmed

`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N`

Affected (1): 192.168.1.60:21

The FTP server lets anyone log in as 'anonymous' without a password. Files it shares can be read (and possibly uploaded) by any device on the network.

Solution: Disable anonymous access in the FTP server settings (vsftpd: anonymous_enable=NO), or remove the FTP service if it is not needed.

Evidence: Login as 'anonymous' accepted: 230 Login successful.

MEDIUM **CVE-2023-48795**

OpenSSH 8.9p1: Terrapin attack: prefix truncation of the SSH transport

CVSS 3.1: 5.9 | EPSS: 55.00% (percentile 78) | PPR: 6.5 | Published: 2024-01-01 | Confidence: May be backported

`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:H/A:N`

Affected (1): 192.168.1.10:22 - OpenSSH 8.9p1

Terrapin attack: prefix truncation of the SSH transport. (Demo data for screenshots.)

Solution: Update OpenSSH 8.9p1 to the latest version.

Evidence: Version-based match: OpenSSH 8.9p1 announced on port 22.

https://nvd.nist.gov/vuln/detail/CVE-2023-48795

MEDIUM **PIS-0001**

Telnet service enabled (cleartext remote login)

CVSS 4.0: 6.0 | EPSS: - | PPR: 5.6 | Confidence: Confirmed

`CVSS:4.0/AV:A/AC:L/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N`

Affected (1): 192.168.1.52:23

The device accepts Telnet connections. Telnet sends user names, passwords and everything typed without encryption, so anyone on the same network can read them. Telnet is also a favourite target of IoT botnets such as Mirai, which try default passwords.

Solution: Disable Telnet and use SSH instead. If the device cannot run SSH, block port 23 on the network and change any default password.

Evidence: Port 23 accepts Telnet connections.

MEDIUM **PIS-0009**

Login page served over unencrypted HTTP

CVSS 4.0: 5.9 | EPSS: - | PPR: 5.1 | Confidence: Confirmed

`CVSS:4.0/AV:A/AC:L/AT:P/PR:N/UI:P/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N`

Affected (1): 192.168.1.52:80

This web page contains a password field but is served over plain HTTP. Passwords typed into it travel unencrypted and can be captured by anyone on the same network.

Solution: Enable HTTPS on the device and redirect HTTP to HTTPS. If that is not possible, only manage the device from a trusted, wired network.

Evidence: http://192.168.1.52:80/ contains a password input field.

LOW **PIS-0013**

Unencrypted FTP service

CVSS 4.0: 2.1 | EPSS: - | PPR: 2.1 | Confidence: Confirmed

`CVSS:4.0/AV:A/AC:L/AT:P/PR:N/UI:P/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N`

Affected (1): 192.168.1.60:21

FTP sends user names, passwords and files without encryption.

Solution: Use SFTP (over SSH) or FTPS instead, or disable the FTP service.

Evidence: 220 (vsFTPd 3.0.3)

Needs manual check

The scanner could see these programs but not their exact version, so known vulnerabilities could be neither confirmed nor ruled out. They are not counted as vulnerabilities and may be false positives: check the installed version as described for each one.

REVIEW **REVIEW-samba**

Samba smbd 4: exact version unknown — 47 CVEs could apply (2 known exploited)

Confidence: Unverified — not a confirmed vulnerability, needs a manual check

Affected (1): 192.168.1.10:445 - Samba smbd 4

Reviewed: Yes

Comment (192.168.1.10:445): Checked on the server: smbd --version = 4.19.5 (patched). False positive.

The scanner can see that this is Samba smbd but not its exact version (Samba smbd 4). Known vulnerabilities depend on the exact version, so from the network they can be neither confirmed nor ruled out. (Demo data for screenshots.)

Solution: Check the installed version: On the server run `smbd --version` (or `apt policy samba`). Compare it with the "fixed

in" versions listed in the evidence.
Evidence: Seen on port 445: "Samba smbd 4" — only the version family (4.x) is visible from the network.

CVEs that affect some 4.x version, worst first:
• CVE-2017-7494 · CVSS 9.8 · KEV · fixed in 4.6.4
• CVE-2020-1472 · CVSS 5.5 · KEV · fixed in 4.12.4
• CVE-2023-3961 · CVSS 9.8 · fixed in 4.19.1
• CVE-2021-44142 · CVSS 8.8 · fixed in 4.15.5
• CVE-2023-34966 · CVSS 7.5 · fixed in 4.18.5
… and 42 more.
https://nvd.nist.gov/vuln/detail/CVE-2017-7494

Informational findings

ID	Finding	Where	Details
PIS-0012	Software version detected	192.168.1.10:22, 192.168.1.10…	OpenSSH 8.9p1

Hosts and services

Host	Port	Service	Software
192.168.1.10	22	SSH	OpenSSH 8.9p1
192.168.1.10	80	HTTP (web)	Apache httpd 2.4.49
192.168.1.10	6379	Redis	Redis 6.0.16
192.168.1.52	23	Telnet	
192.168.1.52	80	HTTP (web)	
192.168.1.60	21	FTP	vsftpd 3.0.3

How the scores work

Confidence
How each finding was established. Confirmed: seen directly (a configuration check, or an Nmap script that tested for it). Version match: the service announced an exact version that NVD lists as vulnerable. May be backported: a version match on a Linux distribution build, which may already contain the fix. Unverified: only an approximate version is visible (e.g. Samba "4"), so known CVEs can be neither confirmed nor ruled out; such software is listed under "Needs manual check" (severity Review) and is not counted as a vulnerability.

CVSS v4.0
Common Vulnerability Scoring System from FIRST: how severe a vulnerability is (0-10). NVD's v4.0 score is used when published; otherwise v3.1, v3.0 or v2.0, as shown next to each score. Proton's own configuration checks (PIS-xxxx) are scored with CVSS v4.0.

EPSS
Exploit Prediction Scoring System from FIRST: the probability that the vulnerability will be exploited in the wild in the next 30 days, with its percentile among all CVEs. Updated daily.

KEV
Listed in CISA's Known Exploited Vulnerabilities catalog: attackers are known to use it. Fix these first.

PPR (VPR-style)
Proton Priority Rating, 0-10. Tenable's VPR is proprietary and cannot be reproduced; PPR follows the same idea with public data: 60% CVSS impact + 40% threat, where threat is 10 for KEV entries, otherwise 10 x sqrt(EPSS) (2.0 when no EPSS exists yet). The Top 10 is ordered by PPR.

Version-based matching
CVEs are matched from the software version each service announces, like remote version checks in other scanners. Linux distributions back-port fixes without changing version numbers; such findings say so and should be confirmed with the installed package version.

This report was produced by an automated scan. It can miss vulnerabilities (closed or filtered ports, software that hides its version) and can include false positives. Only scan networks you own or have permission to assess.